

Hathor - Weekly Report - Week 3

Summary

This week completed Milestone 1 (Local Platform, Gateway, Auth, and Web Shell) and made major progress on Milestone 2 (Catalog, Designer, Cart, and Pending Orders). Key completed tasks for Milestone 2 include Catalog Publication & Internal Quote (M2.1), Cart Management & Ownership Verification (M2.3), and Idempotent Order Initialization with Checkout UI (M2.4). Issue M2.2 (Store Page Designer, Direct LLM Copilot, and Agentic Store Builder) remains actively in progress.

Completed Tasks

Milestone 1 Completed: Local Platform, Gateway, Auth, and Web Shell

1.3: Gateway Edge Controls

- **Status:** Completed
- **Namespace Proxying:** Fully operational reverse proxy routing all public namespaces to downstream services (/api/v1/user/* → Auth; /api/v1/store/* and /api/v1/creator/* → Catalog; /api/v1/cart/* and /api/v1/txn/* → Commerce; /api/v1/inventory/* → Library).
- **Private Path Isolation:** Edge rules blocking all external inbound requests from reaching private /internal/* endpoints.
- **Edge Middleware & Security Headers:** Strict origin CORS, Helmet CSP (X-Frame-Options: DENY), payload size caps, and IP rate limiting on public auth routes.
- **Observability:** X-Correlation-ID tracing across requests and standardized downstream error responses.

1.4: Auth, Sessions, & Service Tokens

- **Status:** Completed
- **Password & Account Security:** Argon2id password hashing, gamer default role, and Cloudflare Turnstile CAPTCHA validation.
- **RS256 Access JWTs & JWKS:** 10–15 min RS256 access tokens with claims and public JWKS distribution (/api/v1/user/.well-known/jwks.json).
- **Rotating Refresh Tokens:** Opaque refresh token families in HttpOnly, Secure, SameSite=Lax cookies with automatic revocation on reuse.
- **Session Control & Internal Identity:** authorization_version tracking for session revocation, secret-gated CLI admin bootstrap, and 5-minute scoped internal service JWTs.

1.5: Web Shell & Auth Experience

- **Status:** Completed
- **TanStack Application Shell:** apps/web application shell with Router, Query, global layout, and typed API client integration.
- **In-Memory Access Tokens:** Access JWTs stored strictly in React Context to prevent XSS.
- **Session Recovery & Protection:** Background refresh via POST /api/v1/user/refresh, CSRF protection, and route guards.

1.6: Seed Catalog Read Path & Storefront Shell

- **Status:** Completed
- **Seeding & API:** PostgreSQL migrations seeding demo published games, tags, creators, and themes in EGP. Exposed `/api/v1/store/games` and `/api/v1/store/games/:id`.
- **Integration Verification:** Verified local flow: register → login → GET `/user/me` → browse catalog storefront.

Milestone 2 Tasks Completed This Week

M2.1: Implement Catalog Publication, Pricing, And Internal Quote

- **Status:** Completed
- **Publication State Machine & Admin Status Route:** Implemented state transitions in `catalog-service` (draft → pending_review → published / rejected / suspended). Restricted status mutations to Admins via PATCH `/api/v1/admin/games/:gameId/status` with immutable audit logging.
- **Internal Quote API & Decimal Precision:** Built private route GET `/internal/v1/catalog/quotes/:gameId` requiring internal RS256 service JWTs (aud=catalog-service, scope=catalog.quote.read). Formatted financial amounts as PostgreSQL `numeric(10, 2)` serialized into exact EGP strings.

M2.3: Implement Cart And Ownership Check

- **Status:** Completed
- **Authoritative Cart CRUD API:** `commerce-service` manages carts and `cart_items` in `commerce_db` bound to user identity. Maintained atomic integer version sequence on carts to detect stale checkout attempts.
- **Scoped Library Ownership Check:** Integrated private inter-service call POST `/internal/v1/library/ownership-check` (aud=library-service). Cart items already owned by the user are flagged as `already_owned` and blocked from checkout.

M2.4: Implement Idempotent Order Initialization And Checkout UI

- **Status:** Completed
- **Idempotent Order Initialization Service:** POST `/api/v1/txn/init` enforces Idempotency-Key (UUID v4) headers and request hashing in `commerce_db.idempotency_records`. Calculates totals server-side using internal catalog quotes; creates orders (payment_pending, 15-min expiry) and `order_items` snapshots.
- **Checkout UI & Payment-Pending View:** Built checkout interface in `apps/web` displaying cart items, server-calculated totals, simulator payment method options (`sim_fawry`, `sim_vodafone_cash`, `sim_instapay`), and transition to the payment-pending order screen.

Work In Progress (Started This Week)

M2.2: Implement Store Page Designer, Direct LLM Copilot, And Agentic Store Builder

- **Status:** In Progress
- **Theme Validation & Ownership Guard (M2.2.1):** Enforcing creator ownership (`creator_id == caller_id`) on PUT `/api/v1/creator/games/:gameId/theme` (HTTP 403 on mismatch) and validating theme schemas against `ThemeDocument` rules (HTTP 422 on bad structure/script injection).
- **Direct LLM Theme Copilot (M2.2.2):** `AIDesignProvider` adapter converting natural language prompts into RFC 6902 JSON Patch arrays over `ThemeDocument` with schema output constraints.
- **Agentic Store Builder & HITL UI (M2.2.3):** Tool-calling agent loop in `ai-agent-worker` (`get_game_metadata`, `extract_asset_palette`, `generate_theme_patch`, `validate_theme_schema`, `draft_marketing_copy`) paired with `apps/web` live preview, diff inspector, and Creator Human-In-The-Loop (HITL) approval gate.

Next Week Objectives (Week 4)

1. Finalize Milestone 2 Remaining Scope:

- Finish Issue M2.2 (Store Page Designer, Direct LLM Copilot, and Agentic Storefront Builder with HITL UI).
 - Complete Issue M2.5 (Catalog, Cart, and Checkout contract/threat tests) and Issue M2.6 (RAG Semantic Search & Vector Indexing).
2. **Kick off Milestone 3 (Payment Simulator, RabbitMQ, And Entitlements):**
- **M3.1 Provision RabbitMQ Topology & Outbox Worker:** Set up durable exchanges, queues, DLQ, and outbox publisher confirms per AsyncAPI contracts.
 - **M3.2 Implement Payment State Machine & Simulator Callback:** Build payment event tracking, HMAC callback verification, provider event uniqueness, and outbox publishing (`commerce.order.paid.v1`).